VITALGUARD-JODALCHEONG 데이터베이스 종합 감사 보고서

> 정적 PostgreSQL DDL 11개 파일 + 앱 DB 코드(dashboard-web) 대상. 라이브 DB 미연결. 감사일 2026-06-28 · 대상 1인 개발(우진, 광주, 자체서버) · 에이전트 10개 + 교차검증

Part 1. 경영 요약

1.1 전체 현황

지표	값	판정
전체 건강 점수	**46 / 100**	주의 (상용화 전 시정 필수)
Critical	**1건**	민감정보 평문 저장 (PRIV-01)
High	**9건**	비밀번호·백업·인덱스·도메인무결성 등
Medium	**22건**	성능·정규화·보존정책·문서화
예상 총공수	**약 96시간**	1인 기준 약 2.5주 (P0~P2 집중 시)
컴플라이언스 점수	**28 / 100**	개인정보보호법 4대 안전조치 공백

1.2 컴플라이언스 상태 (개인정보보호법)

영역	상태	근거
민감정보(건강·생체) 암호화	**미준수**	전 DDL `pgcrypto` / `encrypt` 0건
비밀번호 일방향 암호화	**부분 미준수**	T_SAFEGUARD.SG_PWD 해시 강제 없음 (앱 users 는 scrypt 양호)
접속기록 보관(pgaudit)	**미준수**	전 DDL `pgaudit` 0건
보유기간·파기 정책	**미준수**	전 DDL retention/TTL 0건, 무한축적
가명처리·동의기록	**미준수**	consent 테이블·가명 식별자 0건
전송구간 암호화(SSL)	**미준수**	`sslmode=disable` (lib/db.ts:96)

긍정 소견. 주민등록번호 컬럼은 11개 DDL 에 직접 없음. 앱 인증(users)은 scrypt 일방향 해시·fail-closed·IP 잠금으로 양호. 전 DB 접근 경로가 파라미터라이즈드로 SQL 인젝션 표면 사실상 없음. SECURITY DEFINER 함수 0건으로 권한상승 경로 없음.

1.3 Top 5 우선순위

순위	항목	심각도	공수	합의 근거
1	민감정보(건강·생체·위치) 평문 저장 + DB 계층 보호(암호화·RLS·접속로그) 전무	Critical	26h	5개 에이전트 수렴, grep 입증
2	T_SAFEGUARD.SG_PWD 평문 가능 설계 — 관리자 자격 해시 강제 부재	High	3h	4개 에이전트 중복
3	백업/복구 기반 자체 부재 — pg_dump·WAL·PITR 미정의	High	8h	운영 데이터 영구손실 위험
4	VITALGUARD 6개 FK + T_SENSING 시계열 인덱스 전무 — 풀스캔·삭제락	High	1.5h	3개 에이전트 일치, 저공수·고효과
5	시계열 리텐션·파티셔닝·정기 VACUUM/ANALYZE 자동화 부재	Medium	6h	5개 에이전트 수렴

1.4 핵심 구조적 리스크

가장 큰 단일 리스크는 **DB 계층 방어가 전부 비어 있어 현재 멀티테넌트 격리·민감정보 보호가 전적으로 앱 코드 단일 의존**이라는 점이다. 앱은 단일 공유 계정으로 접속하므로, DB 직접접속이나 신규 라우트 한 곳만 우회하면 타사 작업자의 건강·생체·위치 정보 전체가 평문으로 노출된다. RLS·GRANT/REVOKE·암호화·접속로그가 모두 0건이다.

Part 2. 에이전트별 상세 발견사항

2.1 보안 감사 (점수 38/100)

ID	제목	심각도	근거 파일	공수
SEC-RLS-001	전 스키마 RLS 정책 0건 — 멀티테넌트 격리 없음	High	vitalguard_safeprocure_full.sql 전 테이블	8h
SEC-PWD-001	SG_PWD 해시 강제 없는 평문 가능 설계	High	:123-134	3h
SEC-PII-001	민감정보 전 테이블 평문 + 암호화 설계 부재	High	:65,77,126,137 외	12h
SEC-PRIV-001	PUBLIC 스키마 REVOKE 부재	Medium	:31, 전 DDL	2h
SEC-FN-001	트리거 함수 search_path 미고정	Low	doc_media/02,03	1h
SEC-PII-002	signed_url 평문 영속화	Low	doc_media/01:133-134	2h
SEC-APP-001	앱 SQL 전부 파라미터화 (긍정)	Info	lib/db.ts:373-394	0h

대표 수정 — RLS 활성화 (앱이 `app.company_idx` 세션변수 주입 전제).

```
BEGIN;
ALTER TABLE public.T_WORKER ENABLE ROW LEVEL SECURITY;
ALTER TABLE public.T_WORKER FORCE ROW LEVEL SECURITY;
CREATE POLICY p_worker_tenant ON public.T_WORKER
  USING (COMPANY_IDX = current_setting('app.company_idx', true)::bigint);
-- T_SITE/T_SAFEGUARD/T_SAFETY_EXPENSE/T_SENSING/T_ALERT 동일 패턴 확장.
COMMIT;
```

2.2 성능 감사 (점수 62/100)

ID	제목	심각도	근거 파일	공수
PERF-01	6개 FK 컬럼 전부 인덱스 누락	High	full.sql:191-208	1h
PERF-02	T_SENSING 시계열 인덱스 부재	High	full.sql:82-91	0.5h
PERF-03	calendar/media GET presignDownload N+1	Medium	calendar/media/route.ts:34-57	2h
PERF-04	auditWorkerDays substr·정규식 인덱스 미사용	Medium	lib/db.ts:524-561	2h
PERF-05	FALL_SELECT raw_json::jsonb 매행 파싱	Medium	lib/db.ts:719-759	3h
PERF-06	alerts 정렬키(ts) 인덱스 불일치	Medium	lib/db.ts:208-219,614	0.5h
PERF-07	doc_media LATERAL 최신1건 복합인덱스 부재	Medium	doc_media/01,03	1h
PERF-08	doc_media 단일 asset_id 인덱스 중복	Low	doc_media/01,03	0.5h
PERF-09	fall_ml.v_fall_all worker_id 인덱스 비대칭	Low	fall_ml/03:67-76	0.3h
PERF-10	시계열 파티셔닝 미적용	Info	full.sql, lib/db.ts	8h

대표 수정 — FK 인덱스 6종 (멱등·트랜잭션).

```
BEGIN;
SET search_path TO public;
CREATE INDEX IF NOT EXISTS idx_t_worker_company     ON T_WORKER (COMPANY_IDX);
CREATE INDEX IF NOT EXISTS idx_t_sensing_worker      ON T_SENSING (WORKER_IDX);
CREATE INDEX IF NOT EXISTS idx_t_site_company        ON T_SITE (COMPANY_IDX);
CREATE INDEX IF NOT EXISTS idx_t_safeguard_company   ON T_SAFEGUARD (COMPANY_IDX);
CREATE INDEX IF NOT EXISTS idx_t_alert_sensing       ON T_ALERT (SENSING_IDX);
CREATE INDEX IF NOT EXISTS idx_t_safety_expense_site ON T_SAFETY_EXPENSE (SITE_IDX);
COMMIT;
-- 대용량 테이블은 트랜잭션 밖 CREATE INDEX CONCURRENTLY 권장.
```

```
BEGIN;
SET search_path TO public;
CREATE INDEX IF NOT EXISTS idx_t_sensing_worker_created ON T_SENSING (WORKER_IDX, CREATED_AT
DESC);
CREATE INDEX IF NOT EXISTS idx_t_sensing_created        ON T_SENSING (CREATED_AT);
COMMIT;
```

2.3 데이터 무결성 (점수 68/100)

ID	제목	심각도	근거 파일	공수
DI-01	SG_ID UNIQUE 누락 — 중복 관리자 계정 허용	High	full.sql:118-129	0.5h
DI-02	COMPANY_BNO UNIQUE·형식 CHECK 누락	Medium	full.sql:40	0.5h
DI-03	코드성 컬럼 CHECK 없음	Medium	full.sql:86,145,168,173	2h
DI-04	vital_samples_galaxy 시각 TEXT	Medium	galaxy.sql:36,65	3h
DI-05	fall_events 도메인 CHECK 전무	Medium	fall_ml/01,02	2.5h
DI-06	QTY INTEGER vs 주석 BIGINT 불일치	Low	full.sql:171 vs :16	0.25h
DI-07	연락처·이메일·혈액형 형식 CHECK 없음	Low	full.sql:65,66,126	1h
DI-08	file_sha256·confidence·GPS 범위 CHECK 누락	Low	doc_media/01	1h
DI-09	T_SAFEGUARD PK INT IDENTITY 비일관	Low	full.sql:120	0.5h
DI-10	doc_media 최신성 타이브레이크 (참고)	Info	doc_media/01,03	0.5h

대표 수정 — SG_ID UNIQUE (테넌트 정책에 따라 택일, 중복 진단 선행).

```
BEGIN;
ALTER TABLE T_SAFEGUARD ADD CONSTRAINT uq_safeguard_sgid UNIQUE (SG_ID);
-- 회사별 유일 정책이면 위 대신:
-- ALTER TABLE T_SAFEGUARD ADD CONSTRAINT uq_safeguard_company_sgid UNIQUE (COMPANY_IDX, SG_ID);
COMMIT;
```

2.4 스키마 설계/정규화 (점수 62/100)

ID	제목	심각도	근거 파일	공수
SCHEMA-001	fall_events/fall_events_2nd ~31컬럼 중복 정의	High	fall_ml/02:19-77, 03:20-62	3h
SCHEMA-002	hr_delta_* 계산 종속 (3NF 위반)	Medium	fall_ml/01,02,03	2h
SCHEMA-003	명명 규칙 비일관 (T_대문자 vs 소문자)	Medium	full.sql, lib/db.ts	4h
SCHEMA-004	T_SENSING EAV 구조	Medium	full.sql:82-98	3h
SCHEMA-005	고빈도 시계열 파티셔닝·보존 부재	Medium	lib/db.ts, galaxy.sql, full.sql	6h
SCHEMA-006	worker_id FK 미연결 자유 TEXT	Medium	lib/db.ts, fall_ml, imu_window	5h
SCHEMA-007	런타임 테이블 FK 누락	Medium	calendar_media/01, lib/db.ts	2h
SCHEMA-008	코드값 CHECK 임베드 중복	Low	full.sql:270-289, rate_migration	3h
SCHEMA-009	media_asset GPS 복제 동기화 장치 없음	Low	doc_media/01:47-48	2h
SCHEMA-010	vital_samples 40+ 컬럼 광폭화	Low	lib/db.ts:126-169	4h
SCHEMA-011	T_SAFEGUARD PK 타입 비일관	Low	full.sql:120	1h
SCHEMA-012	ts 타입 TEXT vs TIMESTAMPTZ 불일치	Low	lib/db.ts, galaxy.sql	3h

스키마별 정규화 점수. safeprocure 85, imu_collect 88, doc_media 80, VITALGUARD public 72, 앱 런타임 public 50, **fall_ml 45(최저)**. fall_ml 통합은 1상 적재단계인 지금 비용이 가장 낮다.

2.5 백업/복구 (점수 38/100)

ID	제목	심각도	근거 파일	공수
BR-01	백업/복구 기반 자체 부재 (pg_dump/WAL/PITR)	High	db/ 전체	4h
BR-02	DB 연결 평문 — 백업 전송/덤프 암호화 미보장	Medium	lib/db.ts:96, .env.example:5	3h
BR-03	보존/파기 정책 부재로 백업 보존·법적파기 충돌	Medium	fall_ml, galaxy.sql	5h
BR-04	마이그레이션 백업이 3-2-1 미충족	Low	rate_migration:16	1h

권장 전략. ① 즉시 — cron + `pg_dump --format=custom` + age/gpg 암호화 야간 덤프. ② 3-2-1 — 로컬+외장+클라우드(R2 어댑터 기존 존재). ③ PITR — `wal_level=replica` + `archive_mode=on` +주1회 베이스백업(자체서버 이전 후). ④ 월1회 복구훈련으로 RTO 실측. 목표 RPO 5분(PITR)/24h(덤프만), RTO 30분~1시간.

2.6 개인정보 컴플라이언스 (점수 28/100)

ID	제목	심각도	근거 파일	공수
PRIV-01	민감정보(건강) 평문 저장 — 암호화 전무	**Critical**	fall_ml/02,03, galaxy.sql, full.sql:66	24h
PRIV-02	관리자 비밀번호 해시 강제 부재	High	full.sql:123,134	3h
PRIV-03	접근·열람 로그(pgaudit) 부재	High	db/ 전체	6h
PRIV-04	보유기간·파기 정책 부재	High	fall_ml, galaxy.sql, imu_window	5h
PRIV-05	사업자번호·INVOICE_NO 평문, OCR 전문 유입	Medium	full.sql:40,184, doc_media/01:64	4h
PRIV-06	위치정보(GPS) 평문 저장	Medium	galaxy.sql, fall_ml, full.sql:88	4h
PRIV-07	연락처·이메일·성명 평문 저장	Medium	full.sql:64-65,126-127	3h
PRIV-08	fall_ml 학습셋 가명처리 부재	Medium	fall_ml/02:29-31, 03:25-27	8h
PRIV-09	동의·동의철회·익명화 구조 부재	Low	db/ 전체	6h

대표 수정 — pgcrypto 설치 + 점진 암호화 컬럼 (락·리라이트 동반, downtime).

```
BEGIN;
CREATE EXTENSION IF NOT EXISTS pgcrypto;
ALTER TABLE vital_samples_galaxy ADD COLUMN IF NOT EXISTS heart_rate_enc bytea;
ALTER TABLE vital_samples_galaxy ADD COLUMN IF NOT EXISTS spo2_enc bytea;
-- 키는 DB 외부 시크릿매니저 주입, 평문 컬럼은 백필 후 DROP.
COMMIT;
```

2.7 DB 설정/운영 (점수 58/100)

DB7-001(SG_PWD)·DB7-002(fall_ml CHECK)·DB7-003(FK 인덱스)·DB7-004(vital_samples TEXT·무파티션)·DB7-005(calendar FK 미연동)·DB7-009(보존·접근분리)는 다른 에이전트와 중복. 고유 항목은 DB7-006(fall_events 수동 PK 충

돌위험), DB7-007(verdict='verified' 오판정 — EXIF 부재 사진 통과), DB7-008(risk_tag UNIQUE 누락 — 중복태그 점수 부풀림), DB7-010(IS_RECEIVED CHAR(1) 정보성).

postgresql.conf 권장값(자체서버 4~8GB)은 라이브 SHOW 대조 후 적용. `shared_buffers` 1~2GB, `work_mem` 16~32MB, `max_connections` 30~40(현 풀 max:8 대비 100 과다), `autovacuum_vacuum_scale_factor` 0.05, `statement_timeout` 30s, `lock_timeout` 5s, `idle_in_transaction_session_timeout` 60s.

2.8 유지보수/헬스 (점수 62/100)

MAINT-01(리텐션/파티셔닝/정리 전무)·MAINT-03(ANALYZE 자동화 부재)은 SCHEMA-005·DB7-004 와 수렴. MAINT-02(TEXT 시각열), MAINT-04(imu_window 진실원 분산), MAINT-05(요율 마이그레이션 ALTER 락). pg_cron 으로 시간당 ANALYZE·일일 리텐션·주간 REINDEX CONCURRENTLY 권장. 모니터링 최소셋 — 디스크 85%·장기 트랜잭션 30분·relfrozenxid 1.5억(wraparound)·deadlock·imu 회수누락 알림.

2.9 앱 통합 위험 (점수 72/100)

ID	제목	심각도	근거 파일	공수
APP-01	전 경로 파라미터라이즈드 (긍정)	Info	lib/db.ts 전체	0h
APP-02	풀 타임아웃 미설정 (idle/connection/statement)	Medium	lib/db.ts:103	0.5h
APP-03	calendar_media_comment FK 미연동	Medium	lib/db.ts:348-360	1h
APP-04	안전관리비 요율 이중 진실원 (TS 상수 vs DDL)	Low	safety-cost.ts:29-34	2h
APP-05	민감 데이터 평문 전송 + 암호화/RLS 부재	Medium	lib/db.ts:96 외	6h
APP-06	트랜잭션 경계 부재 — 멀티스텝 비원자적	Low	lib/db.ts:1031,1472	2h
APP-07	IMU 수신 라우트 무인증	Low	fall/imu-window/route.ts	1h
APP-08	ensureImuWindowTable DDL 동기화 의존	Info	lib/db.ts:774-790	0h
APP-09	SECURITY DEFINER 노출 없음 (긍정)	Info	doc_media/02,03	0h

권장 풀 설정. `new Pool({ connectionString, max: 8, idleTimeoutMillis: 30000, connectionTimeoutMillis: 5000 })` + `pool.on('error', …)`.

2.10 문서화/관측성 (점수 62/100)

DOC-001(fall_events public 주석 전무, 민감정보), DOC-002(safeprocure 컬럼 주석 0건), DOC-003(galaxy 27컬럼 중 8개만), DOC-004(격리 스키마 3개 COMMENT ON SCHEMA 누락), DOC-005(fall_ml 민감 컬럼 무주석 + 라벨 enum 차이 미명시). OBS-001(pg_stat_statements 미설정), OBS-002(pgaudit 부재 — 접속기록 의무). COMMENT 부여는 무중단(메타데이터만), 확장 2건만 재시작 수반.

Part 3. 30일 액션플랜

1주차 — P0 (긴급, 약 14.5h)

작업	항목	공수	비고
백업 즉시 구축	BR-01	4h	cron+pg_dump+age 암호화, SQL 아님
SG_PWD 해시 CHECK	SEC-PWD-001/PRIV-02	3h	진단쿼리로 위반 0 확인 후, 해시접두사 정규식 채택
FK 6종 + T_SENSING 시계열 인덱스	PERF-01/02	1.5h	멱등·트랜잭션, 즉시 효과
풀 타임아웃 설정	APP-02	0.5h	코드 1줄
calendar FK 보강	APP-03/DB7-005	1h	고아 정리 + CASCADE DO 블록
pgcrypto 설치 + 암호화 컬럼 1단계	PRIV-01 (1/3)	4.5h	신규 컬럼 추가 (백필·DROP 은 후속)

P0 진입 전제 — SG_PWD 길이/접두사 분포, SG_ID 중복, fall_ml 범위위반 진단쿼리를 먼저 실행해 ADD CONSTRAINT 실패를 방지한다.

2주차 — P1 (높음, 약 30h)

작업	항목	공수
RLS 정책 도입 (앱 세션변수 주입 동반)	SEC-RLS-001	8h
민감정보 암호화 2~3단계 (백필→평문 DROP)	PRIV-01 (2/3)	12h
pgaudit 접속로그 (또는 트리거 감사)	PRIV-03/OBS-002	6h
fall_ml/VITALGUARD 도메인 CHECK	DI-05/DB7-002/DI-03	4h

3주차 — P2 (중간, 약 28h)

작업	항목	공수
시계열 리텐션 cron + autovacuum 튜닝	SCHEMA-005/MAINT-01,03	6h
보유기간·파기 컬럼 + 동의기록	PRIV-04/PRIV-09/BR-03	11h
UNIQUE·형식 CHECK (SG_ID·BNO·연락처)	DI-01/02/07	2h
쿼리 인덱스 (alerts·doc_media·표현식)	PERF-04~08	9h

4주차 — 문서 + 모니터링 (약 16h)

작업	항목	공수
COMMENT 전면 보강 (민감 컬럼·스키마)	DOC-001~005	2.25h
pg_stat_statements + 모니터링 알림셋	OBS-001/MAINT notes	3h
3-2-1 오프사이트 + 월1회 복구훈련	BR-04/BR-01	4h
ts TIMESTAMPTZ 정규화 + 파티셔닝(규모 확인 후)	SCHEMA-012/DI-04/PERF-10	6h
가명처리 도입	PRIV-08	(착수)

Part 4. 한국어 컴플라이언스 보고서

4.1 개인정보보호법 준수 현황 (법령 조항)

의무	법령 조항	현황	위반 등급
민감정보 처리 제한·안전조치	제23조·제29조, 시행령 제30조	건강·생체·혈액형 평문, 암호화 0건	**심각(Critical)**
비밀번호 일방향 암호화	시행령 제30조 제1항제3호	SG_PWD 해시 강제 없음(앱 users 는 양호)	높음
접속기록 보관(최소 1년, 민감정보 2년)	시행령 제30조 제1항제5호, 안전조치 고시 제8조	pgaudit·감사테이블 0건	높음
보유기간 경과 시 파기	제21조	retention/TTL 0건, 무한축적	높음
고유식별정보 처리 제한	제24조·제24조의2	주민번호 컬럼 없음(양호), OCR full_text 유입 위험	중간
위치정보 보호조치	제23조, 위치정보법 제16조	GPS+생체 결합 평문	중간
가명정보 처리	제28조의2	fall_ml 식별자+민감정보 동일 행	중간
동의·동의철회	제15조·제22조·제23조·제37조	consent 테이블 0건	낮음(입증책임 불리)
전송구간 암호화	제29조, 시행령 제30조 제1항제3호	sslmode=disable	중간

4.2 KOSHA / SafetyMonitor 적합성

- **산업재해 자료 보존**. 생체·낙상 자료는 KOSHA 산업재해 자료 보존(통상 3년) 대상으로 추정되나, 현재 백업 기반 자체가 없어(BR-01) 보존 의무와 정면 충돌한다. 리텐션 정책 수립 시 산재자료 보존의무와 개인정보 최소보관 원칙을 함께 검토해야 한다(법무 확인 필요).
- **안전관리비 산정 근거**. SafeProcure 의 safety_cost_rate 는 고용노동부 고시 제2025-11호 별표1(신 4공종)을 반영한다. 다만 앱은 DB 요율표를 조회하지 않고 TS 상수로 계산해 이중 진실원(APP-04)이라, 고시 개정 시 한쪽만 갱신하면 법정 산정과 어긋난다.
- **증빙 무결성**. doc_media 무결성 트리거는 EXIF 부재 사진을 'verified'로 오판정할 수 있어(DB7-007), 조달 증빙 신뢰도를 과대평가한다.

4.3 시정조치 계획

단계	조치	법적 근거 해소
즉시(1주)	백업 자동화·암호화, SG_PWD 해시 강제	제29조, 시행령 제30조
단기(2주)	민감정보 컬럼 암호화, RLS, pgaudit	제23조·제29조, 시행령 제30조
중기(3주)	보유기간·파기 컬럼, 동의기록 테이블	제21조·제22조·제37조
상용화 전	SSL 적용, 가명처리, OCR 마스킹	제24조의2·제28조의2, 위치정보법 제16조

4.4 법적 위험

민감정보(건강)를 처리하면서 암호화·접속기록·파기·가명처리가 모두 부재한 현 상태는, DB·백업 유출 1건으로 작업자 건강프로파일이 그대로 식별·재식별되는 사고로 직결된다. 제23조·제29조 위반 시 과징금(제64조의2)·형사처벌(제71조) 대상이 될 수 있고, 접속기록 부재로 침해사고 시 원인추적·정보주체 통지 의무 이행이 곤란해 감독기관 조사에서 가중 제재 위험이 있다. 1인 자체서버 특성상 침해 시 입증 부담도 크다. **단, 모든 평문/권한/SSL/실데이터 항목은 라이브 진단쿼리로 운영 실태를 확인한 뒤 최종 결론을 내려야 한다.**

부록. 충돌 해소 및 SQL 검증 요약

- **SG_PWD CHECK** — char_length≥60(평문 60자 통과)보다 해시접두사 정규식 `^(scrypt\$|\$argon2|\$2[aby]\$)` 채택(앱 scrypt 포맷 허용).
- **ts TEXT** — 1단계 ISO8601 형식 CHECK(무중단), 2단계 TIMESTAMPTZ 전환은 파티셔닝과 묶어 적용.
- **fall_ml 통합** — 1상에선 양쪽 동일 CHECK 보강(보수적), phase 3차 이상 증식 시 통합 재검토. 라벨 enum 차이(FALL/NO_FALL vs true_fall/false_positive)는 DOC-005 주석 동반.
- **PERF-08** — 반드시 PERF-07 복합인덱스 생성 후에만 단일인덱스 제거(순서 의존).
- **SQL 안전성** — 전 remediation_sql 트랜잭션 래핑·멱등·롤백 양호. 주의 ① SCHEMA-001 의 NOT VALID 직후 VALIDATE 는 락회피 무력화(소량이라 무해). ② VACUUM/CREATE EXTENSION 은 트랜잭션 밖·재시작 필요(주석 명시). ③ 모든 ADD CONSTRAINT 는 선행 진단쿼리로 위반 0 확인 필수.